

The Regulatory Gap in Commercial Data Center Physical Security

Legislative Argument, Policy Instruments, and the CIKR Logical Predicate

Scope: the legislative and regulatory case for mandatory physical security at commercial data centers, including those hosting government and military workloads

Lineage: L2 Policy Companion, document DBA-MA-DC-L2-P-001, in the Design Basis Accident — Military Action Data Center and AI Infrastructure Series; divides its ground with Keeping the Lights On for Everything That Can't Go Dark

Version 1.7

September 2026

Tim Roxey

Eclectic Technologies

T. Roxey, “The Regulatory Gap in Commercial Data Center Physical Security: Legislative Argument, Policy Instruments, and the CIKR Logical Predicate,” Version 1.7, Eclectic Technologies, September 2026.

DOI: <https://doi.org/10.5281/zenodo.22818458>

Current version: https://scubanuke.github.io/publications/dba-dc/DBA-DC-POL_Policy_Companion.pdf

*Audience: legislative counsel, congressional staff, senior policy officials and interagency analysts with regulatory and national security equities. Written to stand alone for a policy audience. UNCLASSIFIED
// FOR OFFICIAL ANALYTICAL USE.*

Section 1 — Purpose and Argument Structure

This document is the policy companion to the Design Basis Accident — Military Action (DBA-MA) Data Center and AI Infrastructure Series. It is addressed to the people who can close the regulatory gap that the series documents identify: legislative counsel, congressional staff, senior policy officials at the Departments of Defense, Homeland Security, and Commerce, and interagency analysts with equities in critical infrastructure security and national security.

This document is written to stand alone. A reader who has not encountered the prior series documents will find sufficient orientation here to follow the argument. A reader who has worked through the series will find that this document draws the analytical threads together into a legislative and regulatory form designed to support action.

The Complete Argument in Brief

The argument this document makes has three parts, and each part is necessary to the others.

The gap. Commercial data centers — including facilities that host classified U.S. government and military workloads — operate under no mandatory physical security standard for kinetic attack threats. No federal regulation requires a threat assessment, no standard mandates a physical countermeasure, no agency has enforcement authority, and no audit process verifies what operators have or have not done. The voluntary framework is the entire framework. A baseline design basis for the data center facility class now exists (DBA-DC-L1), providing the analytical instrument against which actual facility capability can be measured and capital investment gaps identified. A design basis is not a regulatory standard — it does not carry enforcement authority on its own — but it is the foundational instrument that gives a mandatory standard its floor. The gap this document addresses is the absence of mandatory standards; DBA-DC-L1 provides the analytical foundation to make a meaningful mandatory standard achievable.

The predicate. The federal government has designated commercial data centers as critical infrastructure. That designation is a statement of fact: their disruption has national security consequences. A government that has made this designation cannot consistently manage threats to that infrastructure through voluntary guidelines alone. The designation and the framework are internally inconsistent, and the inconsistency is not a technicality — it is an operational condition that a state adversary has now exploited.

The offer. The legislative and regulatory pathway to closing the gap is available, precedented, and actionable. The executive branch can act within existing authority on the most urgent measures. Congress should authorize and direct the remainder. The industry has an equity in the outcome that makes the ask politically viable. The three-part offer structure specifies what each actor should do, in what sequence, and to what standard.

The remainder of this document develops each part of the argument with the precision and evidentiary grounding required to support legislative drafting, regulatory rulemaking, and congressional hearing preparation.

Section 2 — The Regulatory Gap: A Precise Characterization

The regulatory gap in commercial data center physical security is not a matter of insufficient standards or standards that need updating. It is the complete absence of any mandatory standard. That distinction is important because it shapes both the legislative argument and the policy response. Updating existing standards requires rulemaking within an existing regulatory architecture. Creating mandatory standards where none exist requires establishing the architecture first.

What Is Not There

Five specific regulatory instruments exist for the electric utility sector under NERC CIP and for the pipeline sector under TSA Security Directives, and do not exist for commercial data centers.

The first is a mandatory threat assessment requirement. Electric utilities subject to NERC CIP must conduct documented physical security risk assessments that identify critical assets, assess threats to those assets, and determine appropriate protective measures. Data center operators are not required to conduct any threat assessment, document any methodology, or demonstrate any assessment to any regulator.

The second is a mandatory physical security plan. NERC CIP requires utilities to develop, implement, and maintain documented physical security plans that include specific elements such as perimeter security, access controls, monitoring, and response procedures. Data center operators are not required to develop any physical security plan, demonstrate any element of physical security to any regulator, or update their security posture in response to changes in the threat environment.

The third is an audit and compliance verification process. NERC CIP compliance is verified through regular audits conducted by regional reliability organizations under NERC oversight, with findings reported to FERC. Data center operators are subject to no equivalent audit, no compliance verification, and no reporting requirement for physical security.

The fourth is civil penalty authority. NERC CIP violations are subject to civil penalties enforced by FERC, with maximum penalties calibrated to the severity of the violation and the criticality of the affected assets. No agency has civil penalty authority for non-compliance with commercial data center physical security standards because there is no standard against which to measure it.

The fifth is a sector-specific regulatory agency relationship. Electric utilities have FERC and NERC. Pipeline operators have PHMSA and TSA. Commercial data centers have CISA in an advisory role, with no enforcement authority and no mandatory standard to guide compliance.

The NERC CIP Comparison

NERC CIP — the North American Electric Reliability Corporation Critical Infrastructure Protection standards — is the benchmark against which the data center regulatory gap is most usefully measured. Both sectors are CIKR-designated. Both sectors have documented national security consequence profiles. The electric utility sector has a mandatory, audited, and enforced physical and cybersecurity standard. The data center sector has nothing equivalent.

A difference in consequence does not explain the gap. The data center sector is, if anything, more consequential than the electric utility sector from a military readiness perspective, because it hosts the AI decision-support infrastructure that military operations now depend on — infrastructure that runs on power protected by NERC CIP but that itself carries no equivalent protection. The historical sequencing of regulatory development explains the gap: NERC CIP emerged from the policy response to demonstrated vulnerabilities in the grid in the 1990s and 2000s. The equivalent crisis for data centers has now occurred. The regulatory response has not.

What the Voluntary Framework Actually Provides

The voluntary framework governing data center physical security consists of CISA advisory guidance, industry association best-practice publications, and individual operators' security programs. Each element has a value. None of them constitutes a security requirement.

CISA advisory guidance identifies threats and recommends measures. It does not require that operators read it, act on it, document their response to it, or demonstrate any outcome to any agency. An operator who ignores CISA guidance entirely has violated no regulations and faces no consequences from CISA.

Industry association guidelines — the Uptime Institute Tier Classification, AFCOM standards, and Data Center Coalition publications — represent the best thinking of the industry's practitioners. They do not require anything of anyone. An operator that achieves no industry certification, follows no industry guidelines, and implements no industry best practices is in full regulatory compliance because regulatory compliance requires nothing. It is worth noting precisely what the Uptime Institute Tier Standard does and does not address. The Tier Standard covers topology and operational sustainability: power system redundancy, cooling infrastructure redundancy, concurrent maintainability, and operational continuity. It explicitly excludes security, regional weather, building codes, and property usage — the Uptime Institute states this directly, leaving those determinations to facility owners. A baseline design basis for the data center facility class (DBA-DC-L1) has been developed to address exactly the categories that the Tier Standard excludes: extended and catastrophic-duration power supply events, workload-migration and grid-interaction consequences, physical security against deliberate attack, and cross-sector cascading effects. The Tier Standard and the design basis are complementary instruments—neither substitutes for the other, nor for mandatory regulatory standards with audit and enforcement authority. What the private regime does measure, and how tenant contracts and

insurance give it force, is treated in *Keeping the Lights On for Everything That Can't Go Dark*, Part Two.

The voluntary framework produces a security landscape stratified by operator scale, customer composition, and management judgment — not by any minimum mandatory standard. The largest hyperscale operators have invested heavily in physical security because their government and financial-sector customers demand it. Smaller operators, colocation facilities, and enterprise data centers serving less demanding customer bases may have substantially weaker physical security postures. The voluntary framework cannot measure the difference and cannot address it.

The CIPAC Termination as Legislative Context

The Critical Infrastructure Partnership Advisory Council was terminated in March 2025. Its termination is in the legislative context rather than merely institutional history because it removes an argument that would otherwise be made against the mandatory standards case: that the existing voluntary coordination mechanism is sufficient. It is not sufficient, and it no longer exists. The sector has no mandatory framework and no active formal coordination mechanism. The legislative case for mandatory standards is correspondingly stronger. The same termination is used for a different purpose in *Keeping the Lights On for Everything That Can't Go Dark*, which reads it as the loss of the structure that once held cross-sector consequence judgments and records the electricity sector's 2013 request that it be preserved. This document relies on it only as legislative context.

Section 3 — The CIKR Logical Predicate

The CIKR logical predicate is the core legislative argument. It does not depend on the AWS Middle East strikes, on the military AI dependency, or on any particular threat assessment. It depends only on the federal government's own prior determination that commercial data centers are critical infrastructure, and on the logical consequences of that determination.

The Predicate Stated

The argument is three steps, and the conclusion follows necessarily from them.

Step one. The federal government has designated commercial data centers as critical infrastructure under the CIKR framework. The Department of Homeland Security made this designation and reflects a formal governmental determination, not a policy preference or an aspiration.

Step two. The CIKR designation means, by definition, that the disruption of commercial data center infrastructure has national security consequences. This is what the designation means. It is not an inference from the designation — it is the definition of critical infrastructure.

Infrastructure whose disruption does not have national security consequences does not qualify for CIKR designation.

Step three. The federal government currently manages the national security threats to commercial data center infrastructure through voluntary guidelines. Operators are asked to consider CISA guidance. They are encouraged to follow industry best practices. They are invited to participate in information-sharing programs. Nothing is required.

The conclusion. A government that has formally determined that commercial data center disruption has national security consequences and then manages those consequences through voluntary guidelines has adopted a position that is internally inconsistent with its own determination. The inconsistency is not a matter of regulatory philosophy — it is a structural failure. The government has accepted the liability associated with the CIKR designation without assuming the regulatory responsibility that designation entails.

The Predicate Is Not New

The CIKR logical predicate has been applied across all sectors where mandatory security standards have replaced voluntary ones. NERC CIP emerged from the recognition that voluntary reliability standards had not prevented the 2003 Northeast blackout and that the national security consequences of grid disruption required mandatory protection. TSA pipeline security directives emerged from the recognition that voluntary pipeline security guidelines had not prevented significant incidents and that the national security consequences of pipeline disruption required mandatory protection.

In each case, the sequence was: CIKR designation, documented threat, demonstrated gap, mandatory standard. The data center sector has completed the first three steps. The AWS Middle East strikes are both a documented threat and a demonstrated gap. The mandatory standard is the step that has not been taken.

The basis for conferring criticality by cross-sector consequence is not novel to this series; it is established practice in allied jurisdictions. The United Kingdom designates Critical National Infrastructure at the level of individual assets through a structured criticalities process whose later steps require an explicit assessment of cross-sector impact — the consequence a system's failure imposes not only within its own sector but across the sectors that depend on it. Under that method, an asset's criticality can derive from the essential services it supports elsewhere, independent of its weight within its own sector. The United Kingdom applied exactly this logic to the present subject in September 2024, designating data infrastructure as Critical National Infrastructure and placing it, as a sub-sector of Communications, in the same protective category as energy and water. The relevance is twofold. It demonstrates that a peer government already treats cross-sector downstream consequence as a sufficient basis for criticality designation, which is the predicate this section advances. And it demonstrates that an allied government has already crossed the threshold the United States has not: it has moved data infrastructure from

voluntary assurance to designated critical status, while the United States continues to manage the same consequence through voluntary guidelines.

The Predicate Applied to the Data Center Sector

The predicate applies to the data center sector with greater force than it has to any previous sector, for two reasons specific to this sector.

First, the data center sector sits beneath all other CIKR sectors. Every sector that has already received mandatory physical security standards — electric utilities, pipelines, financial institutions — depends on data center infrastructure for its operational technology, its communications, and, increasingly, its AI-assisted decision-making. Failing to apply the CIKR logical predicate to the data center sector is not merely failing to protect one sector — it is leaving unprotected the foundational infrastructure on which all protected sectors depend.

Second, the military AI dependency thread connects commercial data center physical security directly to military readiness in a way that no other CIKR sector presents as acutely. The U.S. military's AI decision support systems run on commercial cloud infrastructure that lacks mandatory physical security standards. The CIKR logical predicate, applied to that specific consequence, is not merely a regulatory consistency argument — it is a defense readiness argument. The Department of Defense cannot consistently invest in AI-assisted military capabilities while accepting that the infrastructure supporting those capabilities is protected only by commercial, voluntary guidelines.

One objection to this predicate must be met directly, because it appears to undercut the argument before it begins: the federal government files data centers under the Information Technology and Communications sectors, not under Energy, and the design basis on which this series rests places the data center facility class within the electric sector. The apparent inconsistency dissolves once two distinct operations are separated. The first is the designation of criticality — the determination that a facility's compromise carries national security consequence. That designation follows the consequence chain across sector boundaries, and for the data center it is conferred precisely by what the facility supports in other sectors: the communications, financial, and military-decision infrastructure that depends on it. The second operation is the placement of the analytical instrument — the question of where the design basis lives. A design basis is built against initiating events and the mitigations that answer them, and for a facility that is fundamentally a large electrical load, the governing initiating events and the available mitigations are electric. Placement follows the events you can design against; criticality follows the consequences that propagate outward. These are not competing answers to one question — they are answers to two different questions, and the data center is the facility class where they resolve to different sectors. The sector-of-record assignment is not disturbed by either: the design basis is placed in the electric sector because that is where its analytical content is governed, while the cross-sector digital-dependency consequence that justifies the criticality designation is

carried by the elevation rule defined in this series, not by a claim that a data center is energy infrastructure.

Section 4 — The Evidentiary Record as Legislative Argument

The CIKR logical predicate is a structural argument that does not require evidence of actual harm. Legislative bodies respond to structural arguments, but they act on evidentiary records. The AWS Middle East strikes provide an evidentiary record of a quality and specificity that is rarely available when making the case for new mandatory standards — typically, the argument must be made prospectively, before the harm occurs. In this case, the harm has occurred. The record is on the table.

What the Record Establishes

Five facts are established by public reporting on the strikes and by the evidentiary record developed in DBA-MA-DC-L3-001, and are available to support congressional hearing testimony, committee markup, and legislative findings. Each is stated here in the form the public record supports, so that a reader outside this series can verify it.

First, a state adversary — Iran — conducted deliberate kinetic attacks on commercial data center facilities operated by U.S. technology companies on March 1, April 1, and April 2, 2026. This is the first confirmed instance of a state adversary targeting commercial data center infrastructure during wartime.

Second, the attacks caused structural damage, power delivery disruption, fire, and water damage from fire suppression activities. Two of the three availability zones in the United Arab Emirates region were critically impaired and one zone in the Bahrain region was disabled, with outages reaching named regional customers in banking and transport. Six months later, in September 2026, the affected Bahrain and United Arab Emirates capacity had still not been restored to service.

Third, the adversary stated its rationale publicly and explicitly: commercial data centers that provide cloud services to a government or military are legitimate military targets. The specific justification was Project Nimbus, a \$1.2 billion contract under which Amazon Web Services and Google provide cloud services to the Israeli government and military.

Fourth, the adversary declared its intent to target a named list of American technology companies. The list ran to seventeen firms, among them Microsoft, Google, Apple, Meta, Oracle, Intel, HP, IBM, Cisco, Dell, Palantir and Nvidia, together with companies outside the technology sector and one operator based in the region. This declaration establishes that, under the adversary's stated doctrine, the targeting envelope encompasses virtually every major U.S. data center operator with government or military service relationships.

Fifth, the physical security framework that governed the affected facilities at the time of the strikes — voluntary guidelines, advisory CISA guidance, no mandatory standards, no audit, no enforcement — did not deter the attacks and did not prevent the damage.

Where the record comes from. The strikes and the rationale are matters of public reporting, not of this series alone. The attacks on Amazon Web Services facilities in the United Arab Emirates and Bahrain, the resulting fire and power disruption, and the Islamic Revolutionary Guard Corps' claim of responsibility were reported in March 2026 by the trade and general press and analyzed in April by academic and policy commentators as the first publicly confirmed military attack on a hyperscale cloud provider. The list of named companies and the doctrine behind it were carried by international outlets at the start of April 2026. The continuing loss of the affected capacity was reported in September 2026. DBA-MA-DC-L3-001 assembles and analyzes that record; it does not replace it, and a reader who cannot obtain the series document can verify each fact above from the press.

The Project Nimbus Rationale as Legislative Finding

The Project Nimbus targeting rationale warrants specific treatment as a legislative finding because it establishes an adversary doctrine with direct implications for every U.S. technology company with government or military service relationships. Iran's position — stated publicly, consistently, and contemporaneously with its actions — is that the government and military service relationships of commercial technology companies make those companies' infrastructure legitimate military targets.

A legislative finding that incorporates this rationale would establish, as a matter of congressional record, that: commercial data center operators with government or military service relationships are within the targeting envelope of at least one state adversary; the adversary has demonstrated technical capability and operational willingness to execute kinetic attacks against that target set; and the voluntary physical security framework in place at the time of the attacks did not address the threat. The legislative finding converts the evidentiary record into a statement of conditions that Congress has formally recognized — a predicate for mandatory standards that is much harder to contest than an executive agency threat assessment.

The Military AI Thread as Defense Authorization Argument

The military AI dependency converts the commercial infrastructure-protection argument into a defense-authorization argument. The adversary's own stated case for the strikes rested on it: Iranian state media asserted that the targeted facilities hosted artificial intelligence systems used by the United States military for intelligence analysis and war simulation. Whether that assertion was accurate in its particulars matters less than what it shows about targeting doctrine, and the general dependency is not in dispute. American military decision-support systems run on commercial cloud infrastructure accredited to Impact Level 6 and operated by commercial providers, and which vendor's models sit behind those systems has already changed once: one

frontier model reached that environment in late 2024 through a partnership with a defense software firm, and the Department of Defense moved its classified artificial intelligence workloads away from that vendor during 2026 after contract terms could not be agreed. The dependency this argument rests on is not any single model vendor. It is that the computing, storage and networking these systems run on sit in commercial data centers that carry no mandatory physical security standard, and a change of vendor does not move a single rack.

The defense authorization argument is direct: the Department of Defense has invested in AI-assisted military capability whose computing infrastructure is protected by a voluntary commercial security framework. The Department cannot consistently make that investment and accept that security posture. Defense authorization language that requires the Secretary of Defense to certify that the physical security of infrastructure hosting DoD AI workloads meets a specified standard — or, in the alternative, to report to Congress on the gap between the current standard and the required standard — creates a legislative vehicle that the defense authorization process is well-suited to carry.

The Hearing Record This Warrants

A congressional hearing on commercial data center physical security, structured around the two evidentiary records this document rests on, would establish the following on the public record: the AWS Middle East strikes — their physical consequences, the service disruption they produced, and the adversary’s stated targeting doctrine; the Volt Typhoon campaign — its dwell times, its living-off-the-land tradecraft, its disruption-preparation purpose, and the detection failure that allowed it to persist for up to five years undetected by affected operators; the military AI dependency and its connection to commercial cloud infrastructure; the regulatory gap and its specific elements; and the voluntary framework’s demonstrated inability to address either the kinetic attack threat the strikes proved or the pre-positioning threat Volt Typhoon proved. That combined hearing record — kinetic proof and pre-positioning proof on a single evidentiary table — would support both mandatory physical security standards legislation and mandatory beneficial ownership disclosure legislation in a package that could not be characterized as speculative or precautionary. It would be characterized as responsive to two documented, concurrent, adversary campaigns against U.S. critical infrastructure.

Section 5 — The Foreign Ownership Gap

The foreign ownership gap is the second legislative argument in this document. It is distinct from the physical security gap — it does not require a kinetic attack to produce national security consequences, and it requires different policy instruments to address. It is, however, related to the physical security gap in a specific way: an adversary with ownership or operational access to data center infrastructure is better positioned to conduct or support kinetic or cyber-physical attacks against that infrastructure than one operating without that access.

What CFIUS Does and Does Not Cover

The Committee on Foreign Investment in the United States is the primary federal mechanism for reviewing foreign acquisitions of U.S. businesses for national security implications. CFIUS has reviewed several data center and telecommunications infrastructure transactions involving foreign-affiliated entities and has blocked or imposed conditions on transactions that presented national security concerns.

CFIUS addresses the acquisition of U.S. businesses by foreign persons. It does not address: existing ownership structures that predate CFIUS review or that were not reviewed at the time of acquisition; operational relationships — management agreements, service contracts, personnel arrangements — that provide foreign-affiliated entities with access to data center facilities or systems without constituting ownership of U.S. businesses; the ongoing monitoring of ownership structures after initial review; or the personnel security of individuals with physical or administrative access to data center facilities under existing ownership arrangements.

The CFIUS gap is structural. The mechanism was designed to review transactions, not to monitor ongoing conditions. A foreign-affiliated entity that acquired data center assets before the current national security concern arose, or that has structured its relationship with U.S. data center assets as an operational agreement rather than an ownership transaction, may be entirely outside CFIUS jurisdiction. The gap between what CFIUS covers and what the foreign ownership threat encompasses is the legislative problem.

The Volt Typhoon record gives this structural gap its evidentiary grounding. The joint CISA, NSA, and FBI advisory of May 2023 and the January 2024 Justice Department disruption operation established that Chinese state-affiliated actors maintained persistent access to U.S. critical infrastructure — communications and energy sector systems — for up to 5 years without being detected by the affected operators. The access was authorized, appearing: legitimate tools, valid credentials, and no anomalous data exfiltration to trigger security monitoring. CFIUS transaction review at the time of acquisition would not have detected this campaign because it was not conducted as part of the acquisition process. It was conducted through the operational access provided by existing relationships. The argument for ongoing monitoring authority rather than transaction-only review is not theoretical — Volt Typhoon proved that transaction-time review misses exactly the threat category that ongoing monitoring is designed to catch.

The Legislative Models

The Foreign Agents Registration Act Model

The Foreign Agents Registration Act requires persons acting as agents of foreign principals in a political or quasi-political capacity to register with the Department of Justice and publicly disclose their activities. FARA's core mechanism — mandatory disclosure of foreign relationships that exert influence over U.S. affairs — is directly applicable to the data center foreign-ownership problem. A data center beneficial ownership disclosure requirement modeled

on FARA would require any entity with ownership or operational control of data center assets in the United States to disclose the full chain of beneficial ownership, including any foreign national or foreign government with a direct or indirect interest.

The Bank Secrecy Act Model

The Bank Secrecy Act and its implementing regulations require financial institutions to maintain records and file reports that assist law enforcement and national security agencies in detecting and preventing money laundering and other financial crimes. The BSA's continuous monitoring and reporting framework — not a one-time transaction review but an ongoing compliance obligation — is the model for data center foreign ownership oversight. A mandatory beneficial ownership disclosure regime for data center operators, with continuously updated requirements and a federal repository accessible to national security agencies, would provide the monitoring capability that CFIUS review alone lacks.

The Telecommunications Sector Model

The telecommunications sector offers the closest existing analogy for what data center foreign-ownership oversight should look like. Team Telecom — the interagency committee that reviews telecommunications licenses held by foreign-affiliated entities — provides ongoing review authority beyond the initial transaction review. The FCC's authority to impose conditions on telecommunications licenses held by foreign-affiliated entities provides a regulatory tool that CISA currently lacks for data center operations. A data center equivalent of the Team Telecom review authority, combined with FCC-equivalent license-condition authority for data center operators serving federal government customers, would provide the ongoing oversight that the CFIUS mechanism does not.

The legislature asks for Foreign Ownership.

The foreign-ownership legislative framework has three components that build on one another.

Component one — mandatory beneficial ownership disclosure. Require any entity operating a commercial data center infrastructure in the United States above a specified capacity threshold to disclose full beneficial ownership, including indirect foreign ownership interests, to a designated federal repository. Require updating within 30 days of any change in ownership. Make the repository accessible to CISA, DoD, the Intelligence Community, and CFIUS.

Component two — ongoing review authority. Authorize CISA, in coordination with DoD and the Intelligence Community, to conduct an ongoing review of disclosed ownership structures and to recommend conditions or restrictions on data center operators whose ownership structures present national security concerns. Model the review process on Team Telecom's authority and procedures.

Component three — enforcement authority. Authorize CISA to impose conditions on data center operators that pose unresolved foreign-ownership national security concerns, up to and including requiring divestiture of foreign ownership interests that cannot be mitigated through operational conditions. Model the enforcement authority on the FCC’s authority to impose license conditions on telecommunications carriers.

Section 6 — The Three-Part Offer

The legislative and regulatory pathway to closing the data center security gap is structured as a three-part offer: what the executive branch can do within existing authority, what Congress should authorize and direct, and what the industry offers that makes the legislative ask politically viable. The three-part structure is derived from the ONG Policy Companion and is adapted here to the specific legislative and regulatory posture of the data center sector.

Part One — Executive Branch Action Within Existing Authority

The executive branch can take several significant actions without new legislative authority. Identifying these actions serves two purposes: it demonstrates that the executive branch is not waiting for Congress to act on the most urgent measures, and it creates a baseline of executive action against which the congressional ask is additive rather than substitutive.

CISA Emergency Security Directive

CISA has authority under the Cybersecurity and Infrastructure Security Agency Act to issue binding operational directives to federal agencies requiring specific security actions. While CISA’s binding directive authority extends to federal agencies rather than to commercial operators, CISA can issue an emergency security directive to federal agencies requiring that any commercial data center facility hosting federal government workloads at or above a specified sensitivity level demonstrate compliance with a specified physical security standard as a condition of continued eligibility for federal contracts. This does not require new legislation — it uses existing federal acquisition authority to impose physical security conditions on commercial operators seeking federal government business.

Federal Acquisition Regulation Modification

The Federal Acquisition Regulation can be modified, through the standard FAR rulemaking process, to require that commercial data center facilities bidding on federal contracts above a specified dollar threshold or sensitivity level demonstrate compliance with a physical security standard developed by CISA in consultation with DoD. FAR modification applies to future contracts and to contract renewals. It reaches the commercial data center sector through its government customer relationships rather than through direct regulatory authority over the

sector. The legal authority exists. The rulemaking requires executive branch commitment to initiate.

Executive Order on Data Center Physical Security

An executive order directing the development of a mandatory physical security standard for commercial data centers hosting federal government and military workloads, establishing an interagency working group to develop the standard within a specified timeline, and directing CISA to exercise its existing authorities to the maximum extent pending development of the mandatory standard, would create the regulatory architecture within which the congressional ask operates. The executive order does not itself create mandatory standards enforceable against commercial operators — that requires legislation. It creates the executive branch framework and timeline pressure that support congressional action.

Part Two — Congressional Authorization and Direction

The congressional ask has four specific elements, each of which requires legislative authorization that the executive branch cannot provide through existing authority.

Mandatory Physical Security Standards

Congress should direct CISA, in coordination with DoD, the Intelligence Community, and the National Institute of Standards and Technology, to develop and publish mandatory physical security standards for commercial data center facilities with a capacity above a specified threshold within 18 months of enactment. The standards should address, at minimum: kinetic attack threat assessment requirements; perimeter security measures calibrated to drone and ground-based attack vectors; power delivery infrastructure hardening; geographic dispersal requirements for facilities hosting federal government and military workloads; and business continuity requirements with demonstrated failover capability. CISA should be granted enforcement authority, including civil penalty authority for non-compliance.

Audit and Compliance Verification

Congress should direct CISA to establish an audit and compliance verification program for mandatory physical security standards, modeled on the NERC CIP compliance verification program. The program should include regular audits of covered facilities by qualified assessors, a compliance reporting requirement, a public reporting mechanism for aggregate sector compliance statistics, and a process by which CISA can require corrective action for facilities that fail to meet mandatory standards within a specified remediation period.

Foreign Ownership Disclosure and Review Authority

Congress should enact the three-component foreign ownership legislative framework developed in Section 5: mandatory beneficial ownership disclosure; ongoing review authority for CISA, in

coordination with DoD and the Intelligence Community; and enforcement authority, including the authority to require divestiture of foreign ownership interests that present unresolved national security concerns.

Defense Authorization Certification Requirement

Congress should include in the next National Defense Authorization Act a requirement that the Secretary of Defense certify to the relevant congressional committees that the physical security of commercial data center infrastructure hosting DoD AI workloads meets a standard specified by the Secretary, in consultation with CISA, as adequate to address the kinetic attack threat demonstrated by the AWS Middle East strikes. In the alternative, the Secretary should report to the committees on the gap between the current physical security standard and the standard the Secretary determines adequate, with a plan and timeline for closing the gap. The certification or report requirement creates accountability without prescribing the solution — it requires the Department to engage with the problem on the record.

Grid Interconnection Conformance Condition

The instruments above establish mandatory standards through new statutory authority. A fourth congressional instrument would attach those standards to a mechanism that already exists and is, as of mid-2026, undergoing active federal expansion: the interconnection of large loads to the transmission system. Throughout 2025 and 2026, at the direction of the Department of Energy under Section 403 of the DOE Organization Act, the Federal Energy Regulatory Commission opened a rulemaking on the interconnection of large loads — those exceeding twenty megawatts — and, on June 18, 2026, issued show cause orders under Section 206 of the Federal Power Act to every jurisdictional regional transmission organization, preliminarily finding their interconnection tariffs inadequate to the demands of data center and other large-load growth. The federal interconnection nexus for large loads is therefore no longer hypothetical. It is being constructed now.

That construction is the opportunity. The reforms FERC is presently advancing concern study timelines, cost allocation, reliability, and load flexibility — they do not address physical security, and they carry no design-basis conformance requirement. Congress should direct that the large-load interconnection framework now taking shape include a physical-security conformance condition: a facility within the covered large-load class should be required to demonstrate conformance to the applicable design basis — the analytical instrument established for its facility class — as a condition of interconnection to the bulk electric system. The mechanism would follow the one Congress used in the Energy Policy Act of 2005, which directed FERC to approve mandatory reliability standards developed and enforced through NERC, and it would require new statutory direction of the same kind. Section 215 of the Federal Power Act, as it stands, supports reliability obligations grounded in an entity's effect on the bulk power system; it does not reach physical security at a load on the ground of what that load serves in other sectors. The instrument therefore rests on two grounds that do different work and should be kept apart. Bulk-

system consequence is the ground for any element of the obligation developed and administered through the reliability standards machinery. Cross-sector consequence is the ground for the designation that defines which large-load classes are covered. It is Congress, and not the existing reliability statute, that would join the two. The advantage of this instrument over a standalone standards mandate is that it requires no new compliance bureaucracy: it conditions a transaction the facility must already complete — connection to the grid — on the security floor the design basis defines. A facility that will not demonstrate conformance does not connect.

Two boundaries should be stated plainly, because they are the instrument's contested edges. First, jurisdiction: load interconnection has historically been a matter of state and local authority, and the assertion of federal jurisdiction over it is the subject of live dispute between FERC and the state regulatory commissions. A conformance condition should be drawn to operate on the federally jurisdictional interconnection to the interstate transmission system, leaving retail and distribution-level connection to the states, and should be framed to complement rather than displace state authority. Second, scope: the conformance condition belongs only on the large-load classes whose compromise meets the cross-sector consequence threshold established elsewhere in this series — it is not a general obligation on all interconnecting load. Bounded this way, the instrument converts an interconnection framework being built for reasons of cost and reliability into the enforcement point for a security floor that the data center sector presently lacks entirely.

Since this instrument was first set out, the reliability route to large loads has moved. On 16 July 2026 FERC directed NERC, in Docket RD26-7-000, to file by 31 December 2026 reliability standards for computational loads, together with registration criteria that would make such loads directly accountable under Section 215 as users of the bulk power system. Registration rests on a load's own effect on reliability — its ride-through, modeling, commissioning and protection behavior — and so offers an existing point of attachment for any bulk-system element of the conformance condition. It does not supply the security element, which still requires the congressional direction this section asks for. The reliability obligations themselves, and the open question of how far registration reaches, are treated in *Keeping the Lights On for Everything That Can't Go Dark*, the policy companion in the generation-mix family, and are not repeated here.

Part Three — The Industry Offer

Mandatory standards legislation is most durable when the affected industry has participated in its development and has equities in its success. The major hyperscale operators — AWS, Microsoft Azure, Google Cloud — have strong commercial and reputational stakes in the physical security of their facilities and are not well served by a regulatory environment that allows less-capable operators to compete without meeting equivalent security standards. The industry offer should be structured to reflect these equities.

Sector Compact on Interim Physical Security Measures

The major hyperscale operators should be invited to voluntarily commit to implementing specified interim physical security measures — counter-drone detection systems, hardening of power delivery infrastructure, and geographic dispersal of federal workloads — within a specified timeline, pending the development of mandatory standards. The compact creates a bridge between current voluntary standards and future mandatory ones, demonstrates industry seriousness, and provides a baseline from which mandatory standards can be calibrated. Operators who participate in the compact should receive recognition in the mandatory standards rulemaking process.

Industry Participation in Standards Development

The major hyperscale operators and the colocation sector should be formally incorporated into the mandatory standards development process through a structured government-industry working group convened by CISA. Industry participation in standards development produces standards that are technically grounded, operationally feasible, and more likely to achieve the security objectives they are designed to achieve. It also produces industry ownership of the outcome — operators who helped write the standard are better positioned to implement it and less likely to contest it.

Information Sharing Commitment

The major hyperscale operators should commit to sharing threat information — including information about kinetic and cyber-physical threats to their facilities — with CISA through a formal information-sharing mechanism that provides appropriate legal protections for the information shared. The absence of a formal information-sharing mechanism since CIPAC's termination in March 2025 has left CISA without the operational threat picture it needs to develop effective mandatory standards. The industry commitment to information sharing is the foundation on which effective mandatory standards can be built.

Section 7 — The Allied Coordination Argument

The allied coordination argument is the international dimension of the legislative case. It connects the domestic regulatory gap to the NATO digital infrastructure security gap. It argues that the same policy logic that produced the Energy sector's international coordination frameworks — following Nord Stream — should produce an equivalent framework for digital infrastructure security.

The Nord Stream Analogy Stated Precisely

Nord Stream was not merely an attack on a pipeline. It was the demonstration that NATO nations had built deep mutual dependencies on shared energy infrastructure without developing a

coordinated physical security framework for that infrastructure. The response — NATO energy infrastructure security planning, coordinated resilience assessments, shared threat information frameworks — was appropriate to the demonstrated gap. It came after the demonstration.

The AWS Middle East strikes are in the data center sector, Nord Stream. U.S. hyperscalers have invested billions of dollars in data center infrastructure in allied nations — the UAE, Saudi Arabia, Ireland, the Netherlands, Japan, and elsewhere. Allied governments have built digital infrastructure dependencies on U.S. hyperscaler cloud services. The adversary struck U.S. hyperscaler infrastructure on allied-nation soil, resulting in consequences borne by the allied government hosting it. NATO has no coordinated physical security framework for digital infrastructure equivalent to the energy infrastructure framework Nord Stream produced. The gap is identical in structure. The demonstration has occurred.

What Allied Coordination Should Require

An allied coordination framework for data center physical security should address the three elements identified by the energy infrastructure framework analogy.

Shared threat assessment. NATO nations hosting U.S. hyperscaler infrastructure should share threat assessments — including kinetic-attack assessments calibrated to the weapon systems and adversary doctrines demonstrated by the AWS Middle East strikes — through existing NATO intelligence-sharing mechanisms. The threat assessment should be updated following each significant incident and shared with host-nation governments and with the hyperscaler operators whose infrastructure is sited in their territory.

Minimum physical security standards for allied-hosted U.S. infrastructure. The mandatory physical security standards developed by CISA for U.S.-based data center facilities should serve as the baseline for allied-nation standards applicable to U.S. hyperscaler facilities hosted in allied territory. NATO should develop a mutual recognition process under which member nations' data center physical security standards are certified as equivalent to the U.S. baseline, creating a common floor without requiring harmonization of domestic regulatory systems.

Host-nation defense obligation for critical digital infrastructure. NATO's collective defense framework should be extended to address the physical defense of critical digital infrastructure hosted in member-nation territory, including U.S. hyperscaler facilities that host workloads supporting alliance military operations. This does not require a new treaty — it requires a formal NATO commitment, analogous to the energy infrastructure commitments made after Nord Stream, that the physical defense of critical digital infrastructure is a collective defense obligation.

The U.S. asks its allies.

The U.S. government's request to allied nations is directly connected to what it is willing to require of its own commercial sector. An allied government that is asked to host U.S. hyperscaler

infrastructure and bear the physical defense burden associated with that hosting will reasonably ask what the U.S. government requires of the operators it is asking to host. The mandatory standards legislation this document advocates is therefore not only a domestic policy measure — it is the prerequisite for a credible request for allied coordination. The U.S. cannot ask its allies to develop mandatory standards for U.S. hyperscaler facilities on their territory while maintaining that voluntary guidelines are sufficient for those same facilities on U.S. territory.

Section 8 — Objections and Responses

Three objections to mandatory physical security standards for commercial data centers are sufficiently predictable and sufficiently well-grounded to warrant precise responses. They will be made in congressional hearings, in regulatory comment periods, and in industry lobbying. The responses below are designed for use in those contexts.

Objection One: Regulatory Burden

The objection: Mandatory physical security standards will impose significant compliance costs on data center operators, particularly smaller operators and colocation facilities, creating a competitive disadvantage and potentially driving consolidation in a sector where consolidation already presents national security concerns.

The response: Regulatory burden is a legitimate consideration in standards development. It is not a sufficient argument against mandatory standards when the alternative is leaving national security-consequential infrastructure unprotected against demonstrated threats. NERC CIP imposes significant compliance costs on electric utilities. TSA Security Directives impose significant compliance costs on pipeline operators. In both cases, Congress and the relevant regulatory agencies determined that the national security consequence of non-compliance exceeded the regulatory burden of compliance. The same determination applies here, with the additional consideration that the AWS Middle East strikes have produced documented harm under the current voluntary framework. The regulatory-burden argument is more compelling before the harm occurs than after it occurs. The harm has occurred.

The burden argument also has an internal tension that mandatory standards resolve rather than create. The largest hyperscale operators — AWS, Azure, Google — already implement substantial physical security measures driven by government customer requirements. Mandatory standards that require equivalent measures from all covered operators level the playing field, which currently advantages large operators at the expense of small ones, whose physical security posture the voluntary framework cannot assess or improve. The competitive concern the objection raises cuts both ways.

Objection Two: Competitive Disadvantage

The objection: Mandatory physical security standards that apply to U.S. data center operators but not to foreign competitors will disadvantage U.S. operators in global cloud services markets, potentially driving customer workloads to less secure facilities operated by foreign providers.

The response: The competitive disadvantage objection assumes that U.S. government and military customers — the customers whose workloads create the national security dependency at the center of this argument — would migrate to less secure foreign providers in response to mandatory security standards. This assumption is not credible. U.S. government and military customers are subject to their own mandatory data handling and security requirements that constrain which providers they can use. Mandatory physical security standards for U.S. data center operators hosting federal workloads do not create a competitive disadvantage for those operators in the federal customer segment — they create a security floor that federal customers should require regardless of regulation.

The allied coordination argument in Section 7 addresses the competitive disadvantage objection: U.S. mandatory standards should serve as the baseline for allied-nation standards applicable to all providers, domestic and foreign, operating in allied-nation markets that host U.S.-dependent workloads. The goal is to raise the international security floor, not to disadvantage U.S. operators relative to foreign competitors.

Objection Three: Sufficiency of Existing Voluntary Frameworks

The objection: The existing voluntary framework — CISA guidance, industry best practices, individual operator security programs — is sufficient, and the major hyperscale operators already implement physical security measures that address the relevant threats. Mandatory standards would duplicate what responsible operators are already doing and impose compliance costs on them without improving security outcomes.

The response: The sufficiency objection was available before March 1, 2026. It is not available after. The voluntary framework that governed the AWS UAE facilities at the time of the Iranian drone strikes did not prevent the attacks, did not limit the physical damage, and did not constrain the service disruption that followed. The strikes are not evidence that the voluntary framework failed at a specific facility — they are evidence that the voluntary framework does not address the threat vector that the strikes demonstrated. A framework that does not require any threat assessment for kinetic attack threats cannot be described as sufficient for kinetic attack threats, regardless of what individual operators may have implemented voluntarily.

The sufficiency objection fails on an additional ground specific to the foreign ownership instruments in Section 5. The Volt Typhoon campaign persisted within U.S. critical infrastructure for up to five years without detection by the affected operators — under the voluntary framework that the sufficiency objection defends. A voluntary framework that failed to detect a Chinese state-affiliated pre-positioning operation running for five years across

communications and energy sector systems cannot be described as sufficient to detect equivalent operations in data center infrastructure. The sufficiency objection for the foreign ownership instruments is answered not by the AWS strikes but by the Volt Typhoon record: the voluntary framework was in place, the threat was active, and the framework did not find it.

The sufficiency objection also fails on audit grounds. The claim that voluntary measures are sufficient cannot be verified because there is no audit process, no compliance verification, and no public reporting on what individual operators have or have not implemented. The major hyperscale operators may voluntarily implement robust physical security measures. The smaller colocation operators and enterprise data center facilities that also host government-dependent workloads may not. The voluntary framework cannot distinguish or address the gap. Mandatory standards with an audit and compliance verification process can do both.

Section 9 — Connections to Series Documents and Legislative Record

Series Document Connections

This document draws its factual predicate from four prior series documents, each contributing a specific element of the legislative case.

DBA-MA-DC-L3-001 (AWS Middle East Strikes) provides the evidentiary record on which Section 4 of this document is built. The complete incident chronology, the adversary doctrine as stated by Iranian state media, and the regulatory gap as demonstrated by the consequences of the strikes are presented in the L3-001 document. Section 7 of L3-001 — the regulatory gap as demonstrated — is the direct predecessor of Section 2 of this document.

DBA-MA-DC-L2-001 (Sector Child) provides the regulatory environment analysis on which Sections 2 and 3 of this document are built. Section 4 of the L2 — the complete regulatory map — is the factual foundation for the characterization of the regulatory gap in Section 2 of this document. The CIPAC termination treatment in Section 4 of the L2 is the source for the legislative context argument in Section 2 of this document.

DBA-MA-DC-L3-002 (Military AI Dependency) provides the defense authorization argument on which the congressional ask in Section 6 is built. The classified-commercial boundary problem, as developed in Section 7 of L3-002, is the specific predicate for the NDAA certification requirement in Part Two of the three-part offer. The operational consequence analysis in Section 5 of L3-002 is the evidentiary basis for the claim that the physical security gap has military readiness consequences that the Department of Defense cannot ignore.

DBA-MA-DC-SI-001 (Series Introduction) provides the series architecture and the four analytical threads that run through all documents. Section 6 of the SI — the regulatory and institutional context — is the series-level statement of the regulatory gap that this document develops into a legislative argument.

DBA-MA-DC-L3-003 (Foreign Ownership, Pre-Positioning, and Latent Threat Activation) develops the Scenario B analysis in full, incorporating the Volt Typhoon evidentiary record. The foreign ownership legislative argument in Section 5 of this document and the Volt Typhoon additions to the sufficiency response in Section 8 rest on the analytical foundation provided by L3-003. Readers who require the full Scenario B consequence analysis, the detection-and-attribution treatment, and the classified-annex interface should read L3-003 in conjunction with this document.

Keeping the Lights On for Everything That Can't Go Dark, the policy companion in the generation-mix family, addresses the same congressional audience and is not a series document. The two divide their ground as follows. This document carries physical and kinetic security of data centers, the critical infrastructure designation argument and its cross-sector consequence predicate, foreign ownership, allied coordination, and the congressional security instruments of Section 6. That paper carries continuity of power across always-on functions, the reliability behavior of large loads and their registration under Section 215, generation concentration and independence, fuel independence and ride-through duration, the transformer reserve, and the question of who now owns cross-sector consequence judgments. The termination of CIPAC, the voluntary data center regime and large-load interconnection are treated in both, each for its own purpose, with each document pointing to the other.

Legislative Record Connections

The legislative record available to support mandatory standards legislation includes the following elements that this document's argument draws on or connects to.

The CIKR designation record. The formal DHS designation of data centers as critical infrastructure under the Communications and Information Technology sector classifications is the administrative record predicate for the CIKR logical predicate argument in Section 3. The designation is not contested — it is the government's own determination that this document uses to argue against the government's own regulatory inaction.

The NERC CIP legislative history. The Energy Policy Act of 2005, which directed FERC to approve mandatory electric reliability standards, is the legislative precedent for the mandatory standards required in Section 6. The congressional findings that supported the NERC CIP mandate — that voluntary reliability standards had not prevented significant grid incidents, that the national security consequences of grid disruption required mandatory protection, and that an audit and enforcement mechanism was necessary to ensure compliance — are the template for the legislative findings that data center mandatory standards legislation should carry.

The CFIUS legislative history. The Foreign Investment Risk Review Modernization Act of 2018, which significantly expanded CFIUS jurisdiction and authorities, is the legislative precedent for the foreign ownership legislative ask in Section 5. FIRRMA's expansion of CFIUS jurisdiction to cover real estate transactions near sensitive government facilities and minority investments in

sensitive technology sectors is directly relevant to the data center foreign ownership problem. The legislative findings that supported FIRRMA — that the existing CFIUS mechanism did not adequately address the full range of foreign investment national security risks — are the template for the findings that data center foreign ownership legislation should carry.

The AWS Middle East strikes. The evidentiary record of the March and April 2026 strikes is the legislative record that no prior mandatory-standards argument in this sector has had access to. It should be entered into the congressional record at the earliest available opportunity — through hearing testimony, committee findings, or a formal congressional resolution acknowledging the strikes and their implications — to establish it as a legislative record predicate for the mandatory standards legislation this document advocates.

Revision History

Version	Date	Author	Description
1.7	17 September 2026	T. Roxey	Publication pass for the Zenodo deposit of September 2026. The cover carries the citation block with the reserved version DOI, and the disposition line no longer describes the document as an internal draft. No change to the argument.
1.6	17 September 2026	T. Roxey	Section 4 is re-sourced so that a reader outside the series can verify it. The five findings now cite the public reporting on the March and April 2026 strikes on Amazon Web Services facilities in the United Arab Emirates and Bahrain, with DBA-MA-DC-L3-001 named as the document that assembles and analyzes that record rather than as its sole source, and a paragraph records where the record comes from. The second finding states the availability-zone damage and the capacity still out of service in September 2026 in place of an unverified service count. The fourth states the size of the named-company list. The military AI paragraph no longer asserts that a named vendor's model is in military use; it reports the adversary's stated rationale as the adversary's, records that the vendor behind those systems changed during 2026, and rests the argument on the infrastructure rather than on any vendor. Four ordinal sentences introduced in v1.5 are repaired.
1.5	17 September 2026	T. Roxey	Conversion to house style at the author's decision of 17 September 2026 on the always-on alignment register. The cover follows the house order, with the document number, series and classification marking carried in the lineage and audience lines. The two bulleted lists in Section 2 (What Is Not There) and Section 4 (What the Record Establishes) are returned to running prose, and the shaded table cells are removed. Section 4 no longer names a specific geographic cluster, in keeping with the scope rule of the

Version	Date	Author	Description
			family it now shares ground with. The revision history lists the newest version first. No change to the argument.
1.4	September 2026	T. Roxey	Clarifications to align this document with Keeping the Lights On for Everything That Can't Go Dark, under the division of ground the author approved on 16 September 2026. Section 6 (Grid Interconnection Conformance Condition) now states that the condition requires new statutory direction rather than an exercise of Section 215 as it stands, and separates its two grounds: bulk-system consequence for any element administered through the reliability standards machinery, and cross-sector consequence for the designation that defines the covered class. A paragraph adds FERC's order of 16 July 2026 in Docket RD26-7-000 directing NERC to file computational-load standards and registration criteria. Pointers to the companion paper are added in Section 2 (CIPAC termination; the voluntary framework) and a division-of-ground paragraph in Section 9. No other change to the argument.
1.3	June 2026	T. Roxey	Three additions to the legislative argument. Section 3 (The Predicate Is Not New) extended with a United Kingdom criticality precedent, establishing cross-sector consequence as an existing allied basis for critical-infrastructure designation. Section 3 (The Predicate Applied) extended with a placement-reconciliation paragraph distinguishing criticality designation (cross-sector consequence) from design-basis placement (where initiating events and mitigations reside). Section 6 Part Two extended with a new instrument, the Grid Interconnection Conformance Condition, attaching a design-basis conformance requirement to the federal large-load interconnection framework opened under FERC Docket RM26-4-000. No change to existing argument structure.